Procédure de détection d'une attaque par Rogue DHCP Serveur

A- EXPLICATION

C'est quoi un serveur DHCP rogue

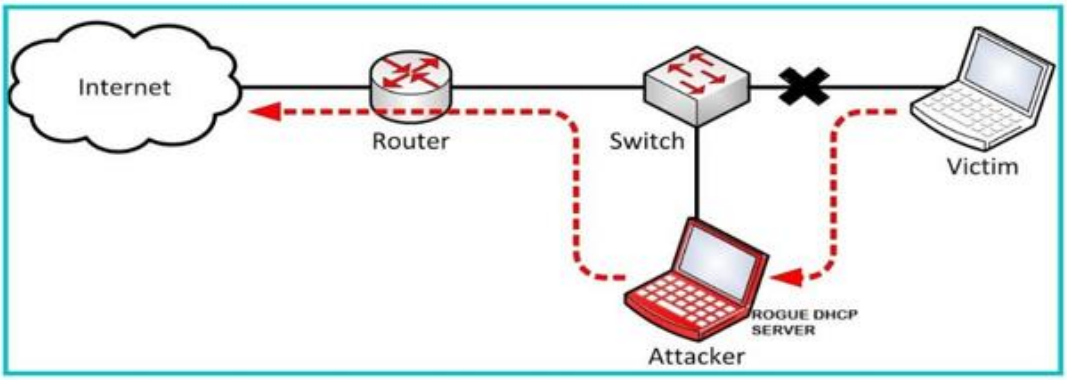
Un **Rogue DHCP** est un serveur DHCP configuré sur un réseau par un attaquant ou par un utilisateur non averti, et qui n'est pas sous le contrôle des administrateurs réseau. Lorsqu'il est introduit dans le réseau, il peut attribuer des adresses IP incorrectes, perturber les connexions ou empêcher les machines clientes d'accéder aux services du réseau.

Principe d'un Rogue DHCP

Le principe d'un Rogue DHCP est très simple : un attaquant met en place un serveur DHCP non légitime sur le réseau. Il se fait alors passer pour un serveur légitime et attribue des adresses IP ainsi que d'autres informations réseau aux machines clientes, en se positionnant comme passerelle par défaut.

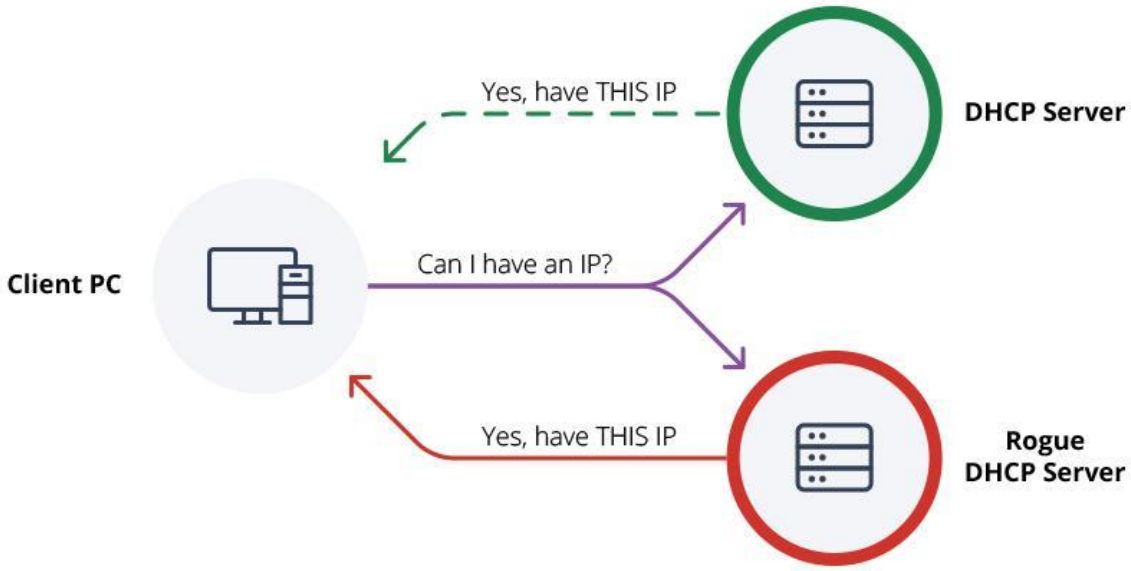
Les clients qui utilisent ces informations deviennent alors vulnérables à des attaques de type **MITM** et autres. En effet, les paquets envoyés par ces machines passent d'abord par le serveur malveillant, ce qui permet à l'attaquant d'intercepter le trafic.

Rogue DHCP Server Attack



Comment fonctionne l'attaque Rogue DHCP

- Un attaquant, disposant d'un appareil, se connecte au réseau puis lance un service DHCP non autorisé.
- Lorsqu'un nouvel appareil rejoint le réseau, ou qu'un appareil existant est allumé, il envoie une requête DHCP s'il est configuré pour obtenir une adresse IP automatiquement.
- Le serveur DHCP légitime et le serveur DHCP non autorisé répondent alors chacun avec leurs propres informations.
- L'équipement récupère l'adresse IP du serveur qui répond en premier. Si c'est le serveur malveillant, les problèmes commencent.
- Ce serveur peut alors attribuer de fausses informations, notamment une passerelle par défaut malveillante. Cela permet de rediriger les machines vers un chemin contrôlé par l'attaquant. Il peut aussi se positionner lui-même comme passerelle, ce qui fait que tout le trafic passe par lui.



Etape de réalisation de l'attaque

Cette attaque se déroule généralement en deux grandes étapes :

- DHCP Starvation
- DHCP spoofing

- **DHCP STARVATION**

À ce niveau, un attaquant envoie un grand nombre de requêtes DHCP (DHCP REQUEST) en utilisant des adresses MAC usurpées. Si le serveur DHCP légitime répond à toutes ces requêtes, les adresses IP disponibles dans sa plage vont être rapidement épuisées. Une fois toutes les adresses IP utilisées, le serveur DHCP ne peut plus attribuer d'adresses aux nouveaux clients. L'attaquant peut alors mettre en place un serveur DHCP non autorisé et répondre aux nouvelles demandes. Cela lui permet ensuite de lancer une attaque d'usurpation DHCP (DHCP Spoofing).



- **DHCP SPOOFING**

Après la réussite de l'attaque DHCP Starvation, l'attaquant peut commencer à distribuer des adresses IP ainsi que d'autres paramètres de configuration TCP/IP aux clients du réseau. Ces paramètres incluent notamment l'adresse de la passerelle par défaut et celle du serveur DNS. Il peut alors remplacer ces adresses légitimes par sa propre adresse IP. Ainsi, tout le trafic du réseau passera par sa machine.

A. PRATIQUE

Passons maintenant à la pratique

Pour simuler cette attaque, nous utilisons une machine Kali (attaquante), une machine Windows qui joue le rôle de serveur DHCP, ainsi qu'une autre machine Windows cliente.

Scénario

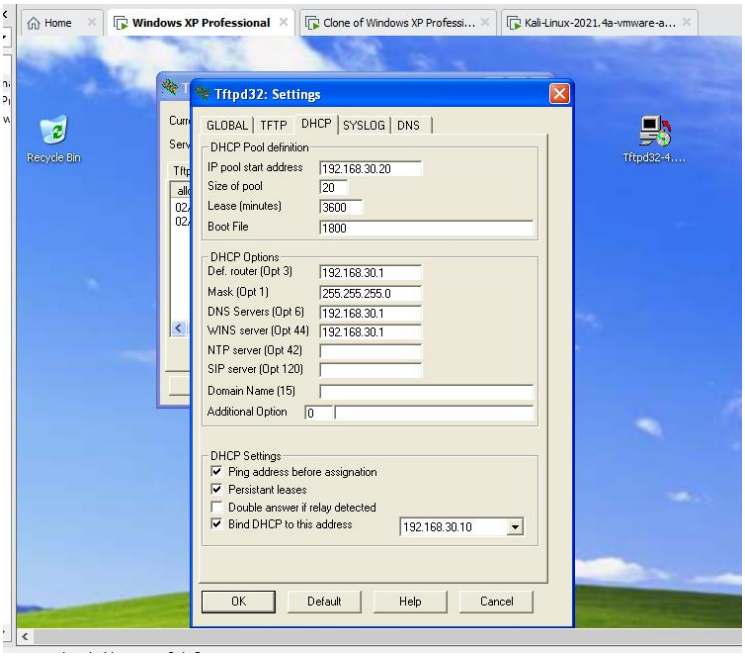
Nous allons configurer un serveur DHCP sur la machine Windows. Ensuite, nous utiliserons la machine Kali pour saturer les baux DHCP en envoyant un grand nombre de requêtes DHCP DISCOVER. Le serveur, en recevant ces requêtes, va répondre avec

des paquets DHCP OFFER. Cela lui fera croire qu'il s'agit de vraies machines. Pour cela, nous utilisons un serveur léger appelé Tftpd32, disponible à cette adresse : https://pjo2.github.io/tftpd64/

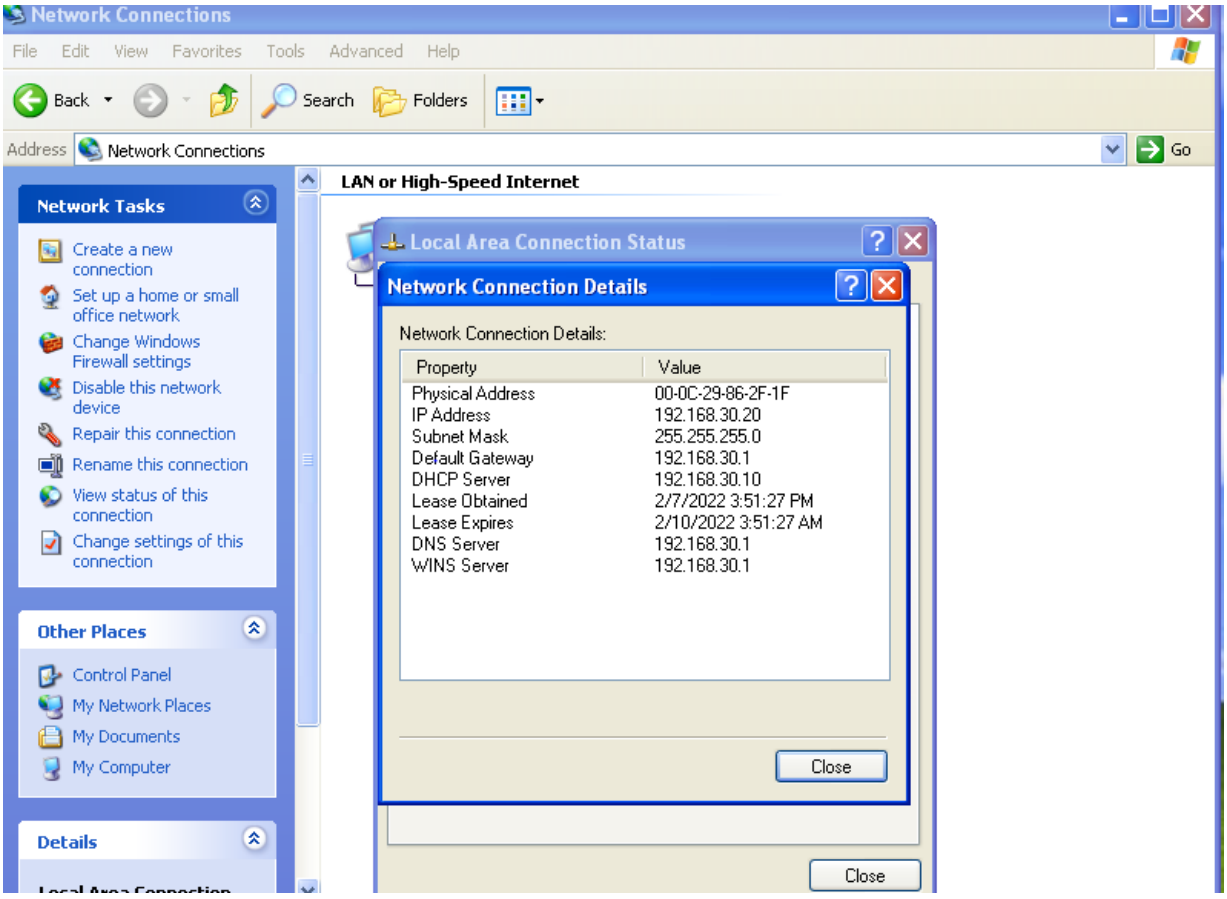
Après téléchargement, on décompresse puis on lance l'application comme un programme classique sous Windows. Une fois ouvert, on se rend dans l'onglet **DHCP Server** et on effectue les configurations nécessaires :

- définition du pool d'adresses IP
- configuration de la passerelle
- configuration du serveur DNS

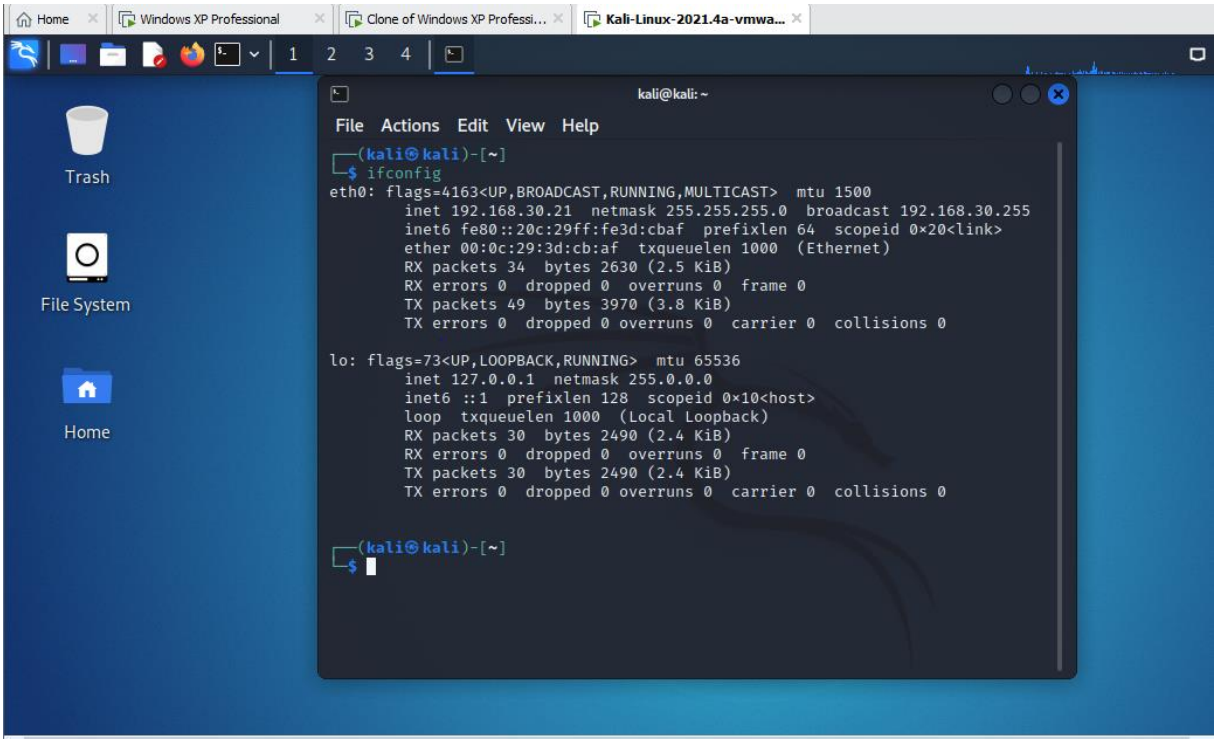
Une fois la configuration validée, les machines du réseau sont prêtes à recevoir des adresses IP depuis ce serveur.



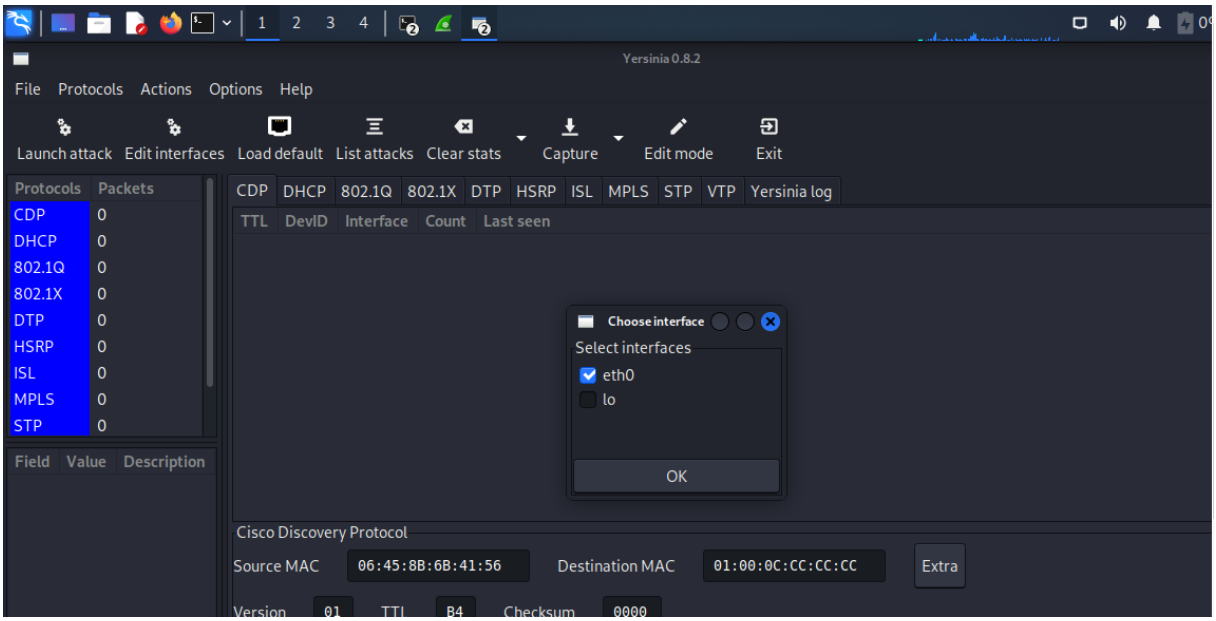
On va sur notre machine cliente puis on fait une demande d'adresse. Apres activation de la carte réseau, un paquet DHCP DISCOVER sera envoyée sur le réseau et comme on peut le voir, notre machine a pu récupérer une adresse IP avec les paramètres DNS et passerelle du serveur.


Network Connections
File Edit View Favorites Tools Advanced Help
Back Search Folders
Address Network Connections
Go
Network Tasks
Create a new connection
Set up a home or small office network
Change Windows Firewall settings
Disable this network device
Repair this connection
Rename this connection
View status of this connection
Change settings of this connection
Other Places
Control Panel
My Network Places
My Documents
My Computer
Details
LAN or High-Speed Internet
Local Area Connection Status
Network Connection Details
Network Connection Details:
Property
Value
Physical Address
00-0C-29-86-2F-1F
IP Address
192.168.30.20
Subnet Mask
255.255.255.0
Default Gateway
192.168.30.1
DHCP Server
192.168.30.10
Lease Obtained
2/7/2022 3:51:27 PM
Lease Expires
2/10/2022 3:51:27 AM
DNS Server
192.168.30.1
WINS Server
192.168.30.1
Close
Close

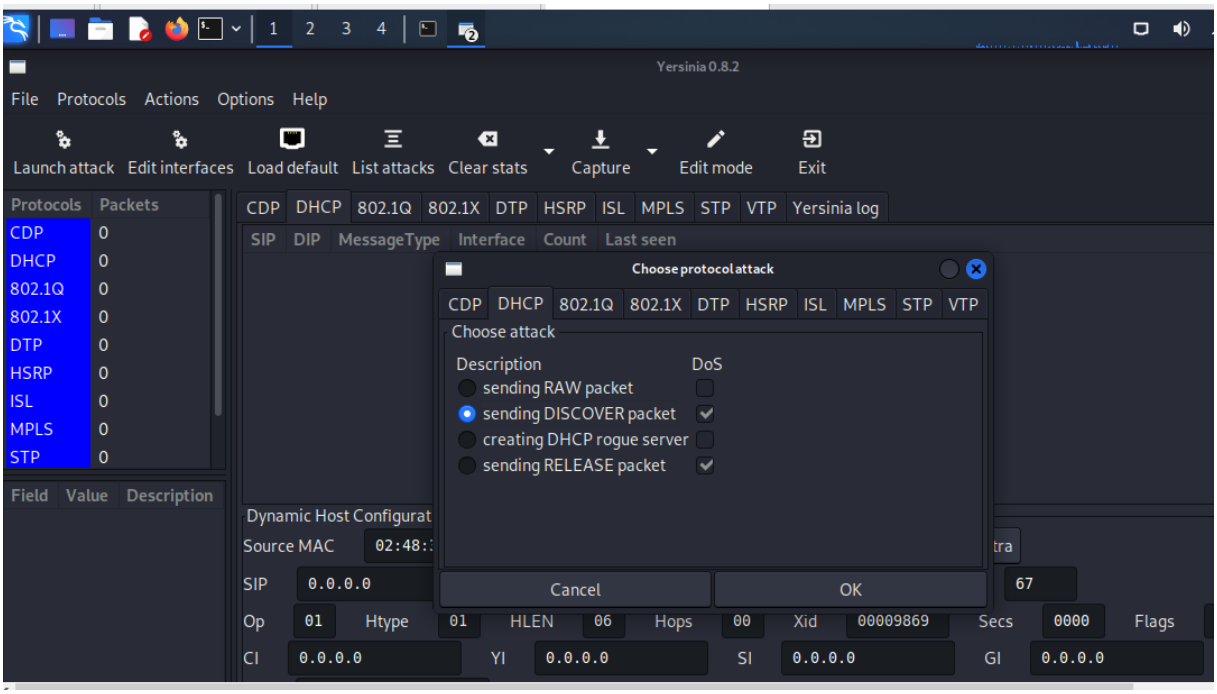
Nous allons à présent saturer le serveur DHCP légitime du réseau. Pour cela, nous utilisons Kali et l'outil Yersinia avec l'option -G. Avant de lancer l'attaque, on vérifie l'adresse IP de la machine afin de s'assurer qu'elle se trouve bien sur le même réseau.



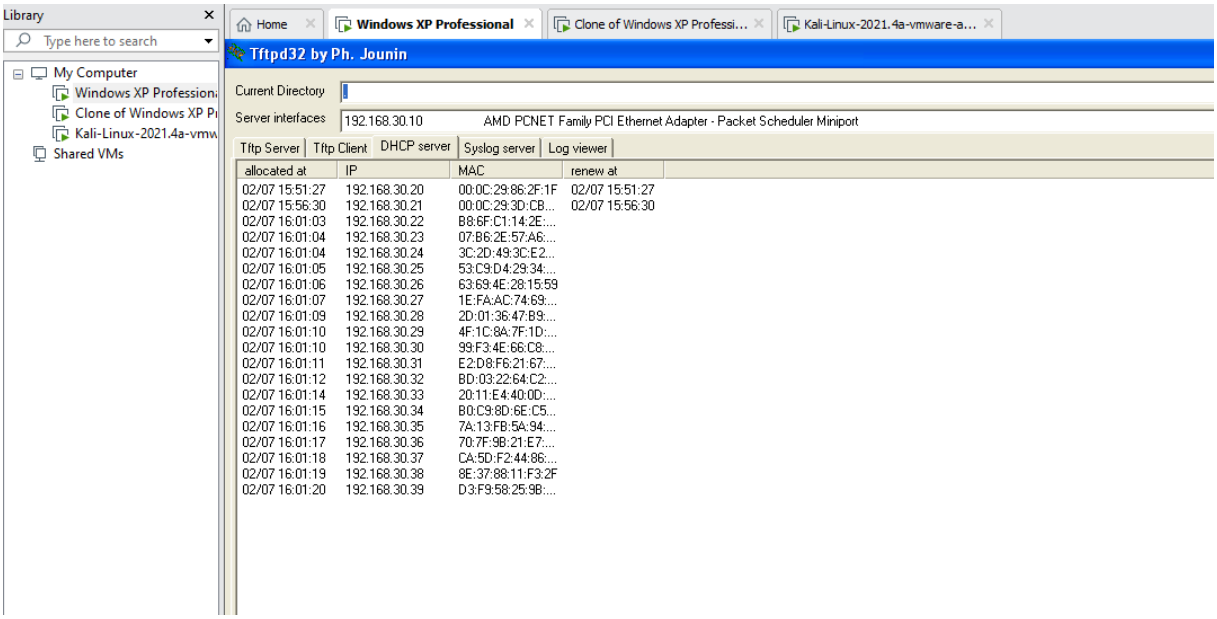
On lance ensuite l'outil. Une fois ouvert, son interface s'affiche. On vérifie d'abord que Yersinia écoute sur la bonne interface réseau en cliquant sur **"Edit interface"**, situé dans l'angle supérieur gauche de la fenêtre.



La première chose à faire est de se rendre dans **Launch Attack**, dans l'onglet DHCP, puis de sélectionner **Send Discover Packet**. Cela permet de faire croire au serveur DHCP que plusieurs machines souhaitent se connecter au réseau. L'objectif est de remplir sa liste de baux.



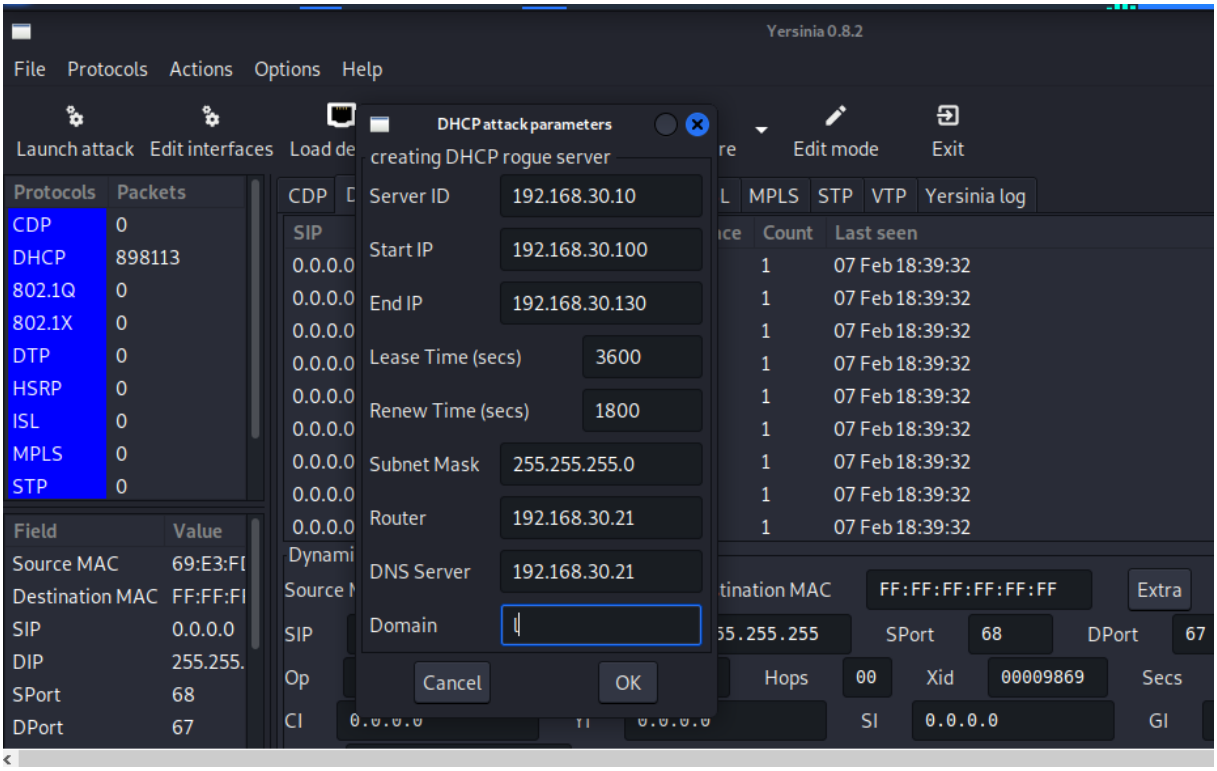
En cliquant sur **OK**, l'attaque se lance. On peut alors constater que la table de baux de notre serveur se remplit progressivement. Ce processus va finir par épuiser toutes les adresses IP disponibles.



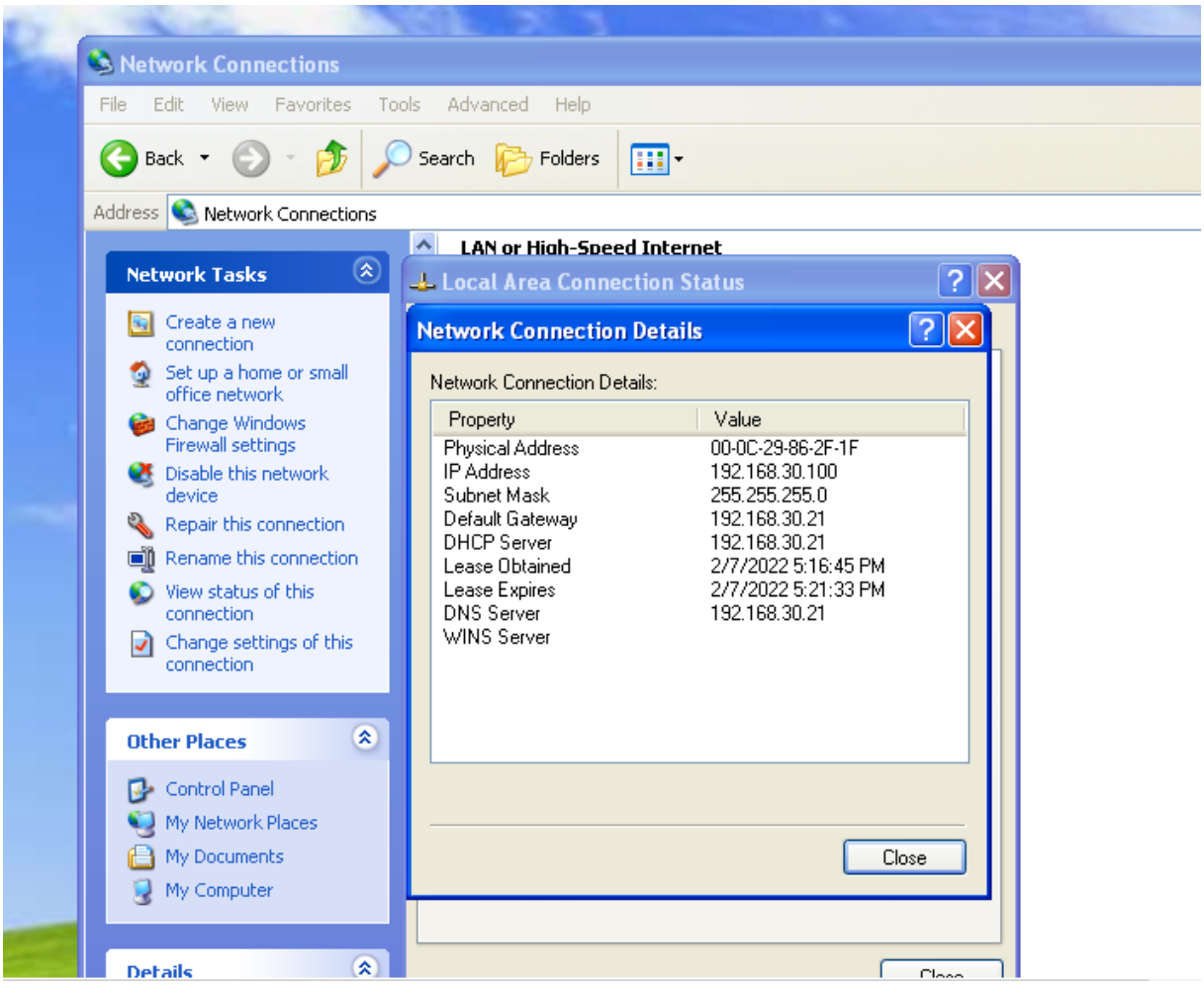
Une fois la table de baux remplie, le serveur ne peut plus répondre aux paquets DHCP DISCOVER. C'est alors une opportunité de mettre en place notre serveur **Rogue DHCP** sur le réseau. On retourne sur Kali, puis dans **Launch Attack**, onglet DHCP, et on sélectionne **Creating DHCP Rogue Server**.

On remplit ensuite les différents champs :

- **Server ID** → adresse IP de la machine attaquante (Kali)
- **Start IP / End IP** → plage d'adresses IP choisie, différente de celle du serveur légitime
- **Lease time** → durée d'attribution d'une adresse IP
- **Renew** → temps de renouvellement de l'adresse
- **Subnet mask** → masque de sous-réseau
- **Router / DNS Server** → adresse IP de la machine attaquante (tout le trafic passera par elle)
- **Domain** → domaine du réseau



Une fois la configuration terminée, on valide puis on se rend sur la machine cliente pour faire une demande d'adresse IP. En activant la carte réseau, on obtient une nouvelle adresse IP appartenant à la plage du DHCP rogue, avec comme passerelle et serveur DNS l'adresse de la machine Kali. Toutes les requêtes de la machine cible sont alors interceptées par la machine attaquante. À ce moment, nous sommes en position de **Man-In-The-Middle (MITM)**, ce qui permet d'intercepter et de contrôler le trafic.



B. Comment détecter l'attaque par rogue DHCP

Détection d'un Rogue DHCP

Il existe plusieurs manières de détecter la présence d'un Rogue DHCP sur un réseau. Voici quelques méthodes :

1) **Désactiver temporairement le serveur DHCP**

En désactivant temporairement le serveur DHCP légitime, les machines du réseau peuvent obtenir une adresse IP depuis un autre serveur, potentiellement non autorisé.

On peut alors utiliser certaines commandes pour identifier ce serveur.

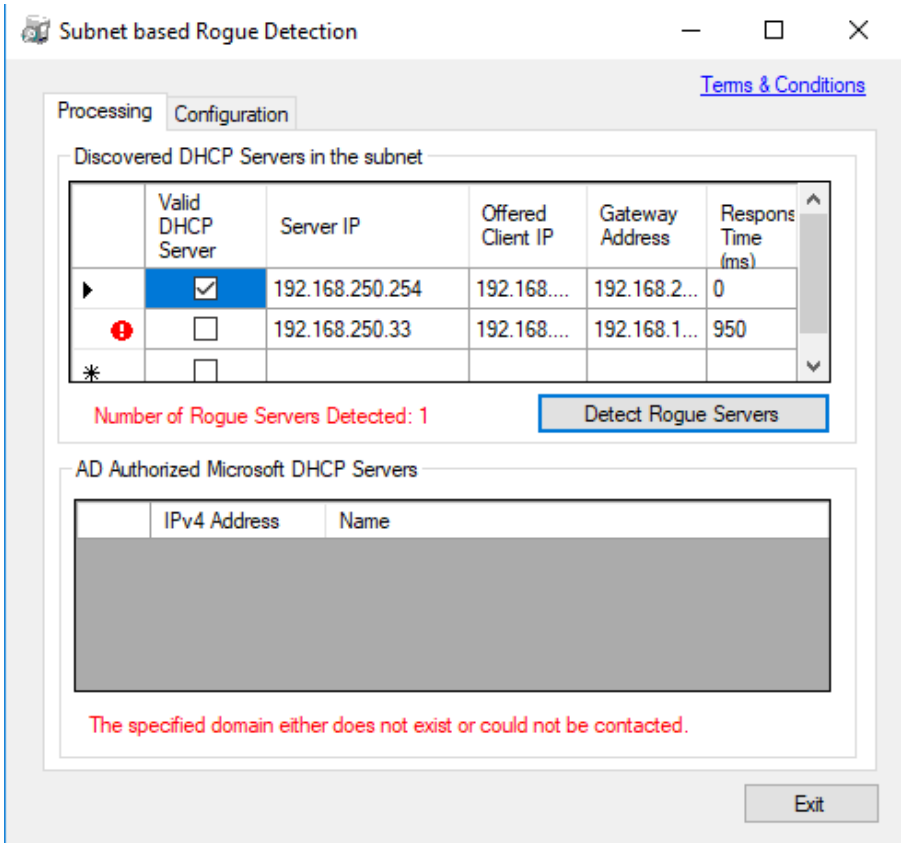
Sur une machine Windows :

- **ipconfig /all** permet d'identifier l'adresse du serveur DHCP
- **arp -a** permet de retrouver son adresse MAC

Ces informations permettent de repérer un serveur DHCP non légitime présent sur le réseau.

2) Utiliser des outils de détection

Il existe plusieurs outils permettant de détecter un serveur DHCP non autorisé. Parmi eux, on trouve l'outil Rogue Check de Microsoft. Avec cet outil, il suffit d'exécuter dhcploc.exe. Il affiche l'ensemble des serveurs DHCP actifs sur le réseau et permet de détecter la présence de serveurs non autorisés. En cas de détection, l'outil génère une alerte.



Ce projet a permis de comprendre le fonctionnement d'une attaque Rogue DHCP et ses impacts sur un réseau. Il met en évidence l'importance de la surveillance et de la détection, car une attaque simple peut rapidement compromettre le trafic et la sécurité des machines.